GUÍA DE TALLER PRÁCTICO: EVALUACIÓN DE VULNERABILIDADES, MATRIZ DE RIESGOS Y CONTROLES DE SEGURIDAD (25%).

Asignatura: Diseño de Arquitecturas de Seguridad TI
Unidad 2: Análisis y evaluación de riesgos, vulnerabilidades y amenazas
Profesor: Marcos Rodríguez Cerda
Institución: INACAP
Modalidad: Presencial
Tiempo estimado: 3 horas pedagógicas

1. APRENDIZAJE ESPERADO Y CRITERIOS DE EVALUACIÓN

Descripción de la evaluación: El estudiante, de manera individual, desarrolla un informe sobre un caso propuesto en el que debe ejecutar pruebas de análisis en un ambiente on cloud y gestionar riesgos, vulnerabilidades y amenazas.

Aprendizaje Esperado

- **2.1:** Analiza la gestión de riesgos, vulnerabilidades y amenazas dentro de una organización, con la finalidad de generar un sistema de gestión de seguridad de la información, seleccionando la metodología más pertinente en virtud del análisis realizado.

Criterios de Evaluación

2.1.1 Reconoce conceptos principales de una evaluación de riesgos, según metodologías nacionales e internacionales.
2.1.2 Utiliza herramientas tecnológicas de análisis de riesgos, vulnerabilidades o amenazas, de acuerdo con la línea base de una arquitectura de seguridad TI.
2.1.3 Interpreta resultados de los análisis de riesgos, vulnerabilidades y amenazas realizados, según framework establecido.
2.1.4 Distingue vulnerabilidades y amenazas, de acuerdo con las situaciones presentadas en el ciberespacio.

2. ESCENARIO Y ARQUITECTURA DEL LABORATORIO

Contexto de Negocio

La organización financiera Banco Valle del Limarí dispone de una infraestructura local que procesa transacciones y datos personales. Para mantener la seguridad operativa, cuenta con una arquitectura compuesta por:

1. **Bastión de Gestión (Windows Server):**
    - **Función:** Puerta de enlace perimetral (Jump Server) y administración centralizada.
    - **Objetivo de Seguridad:** Control de identidades, aplicación de políticas de acceso administrativo y principio de menor privilegio (PoLP).
2. **Servidor de Base de Datos y Servicios (Linux 1 - Activo Crítico):**
    - **Función:** Servidor corporativo que almacena bases de datos y servicios internos.
    - **Objetivo de Seguridad:** Activo protegido que requiere auditoría de servicios, parches y hardening.
3. **Estación de Auditoría y Escaneo (Linux 2 - Analista):**
    - **Función:** Estación de trabajo del equipo de ciberseguridad equipada con utilidades de análisis de vulnerabilidades y escaneo.

3. DESARROLLO DE LA ACTIVIDAD (PASO A PASO)

FASE 1: Identificación de Activos y Criterios de Impacto (ISO/IEC 27005)

1. Analicen el escenario y completen la tabla de inventario de activos de información.
2. Determinen el nivel de valor y criticidad de cada activo en función de la tríada C.I.A. (Confidencialidad, Integridad, Disponibilidad) usando una escala del 1 (Bajo) al 5 (Crítico).
3. Identifiquen a los custodios y propietarios de los datos procesados.

FASE 2: Escaneo Técnico y Descubrimiento de Superficie de Ataque

1. **Desde la estación de auditoría (Linux 2):**
    - Ejecuten un escaneo de puertos y detección de versiones contra el servidor objetivo (Linux 1):
      nmap -sV -sC -p- <IP_Linux_1> -oN escaneo_servicios.txt
    - Si disponen de herramientas especializadas (OpenVAS, Nikto o Lynis), ejecuten un escaneo de configuración y debilidades.
2. **Auditoría sobre el Bastión (Windows Server):**
    - Verifiquen el estado del Firewall de Windows y los puertos de escucha expuestos (ej. RDP en puerto 3389).
    - Auditen las cuentas locales activas y corroboren si cumplen con el principio de menor privilegio (PoLP).
3. Registren capturas de pantalla y evidencias de las salidas de los comandos.

FASE 3: Clasificación Técnica y Priorización CVSS

1. **Diferenciación conceptual:** Para cada hallazgo detectado, clasifiquen de forma explícita:
    - **Vulnerabilidad (Debilidad Interna):** Falla en configuración, software desactualizado, puerto innecesario abierto.
    - **Amenaza (Agente / Evento Potencial):** Actor o incidente capaz de explotar dicha vulnerabilidad (ej. Ransomware, ataque de fuerza bruta, elevación de privilegios).
2. **Cálculo CVSS:**
    - Seleccionen al menos 3 hallazgos relevantes.
    - Asignen la puntuación base CVSS v3.1 / v4 evaluando: Vector de ataque, Complejidad, Privilegios requeridos, Interacción del usuario e Impacto en C.I.A.
    - Filtren falsos positivos considerando el aislamiento del entorno.

FASE 4: Matriz de Riesgo y Estrategia de Tratamiento

1. **Ecuación Básica de Riesgo:**
   Riesgo = Impacto x Probabilidad
    - Asignen valores de Probabilidad (1 a 5) e Impacto (1 a 5) para determinar el Riesgo Inherente (sin controles).
2. **Construcción de la Matriz:**
    - Ubiquen los riesgos en los cuadrantes correspondientes: Riesgo Extremo (Acción Inmediata), Riesgo Alto (Plan de Mitigación), Riesgo Medio (Monitoreo Continuo) o Riesgo Bajo (Aceptable).
3. **Plan de Tratamiento del Riesgo:**
    - Para cada riesgo, seleccionen la estrategia: Mitigar, Transferir, Evitar o Aceptar.
    - Propongan controles específicos alineados con la Línea Base de Arquitectura de Seguridad TI:
        - **Controles Preventivos:** Hardening (cierre de puertos, desactivación de servicios innecesarios, restricción de acceso root por SSH, firewall).
        - **Controles Detectivos:** Configuración de bitácoras y registros de auditoría (auditd en Linux, Visor de Eventos en Windows Server).
        - **Controles Correctivos:** Procedimiento de respaldo seguro y plan de contingencia ante incidentes.
4. Calculen el Riesgo Residual estimado una vez aplicadas las salvaguardas propuestas.

FASE 5: Conexión con el SGSI (Ciclo PHVA) y Conclusiones

1. Expliquen cómo este análisis alimenta la etapa de Planificar (Plan) de un SGSI basado en ISO/IEC 27001.
2. Redacten una síntesis ejecutiva traduciendo los hallazgos técnicos en impacto de negocio (Financiero, Operativo y Reputacional).

4. FORMATO DE ENTREGA

El estudiante deberá entregar un informe individual en formato digital que contenga:

1. Portada y diseño institucional con nombre del estudiante y fecha.
2. Tabla de Inventario de Activos y valoración C.I.A.
3. Evidencia técnica de escaneo (comandos ejecutados y salidas interpretadas).
4. Matriz de Clasificación (Vulnerabilidad vs. Amenaza vs. CVSS).
5. Matriz de Evaluación de Riesgos (Riesgo Inherente vs. Riesgo Residual).
6. Plan de Tratamiento y Controles Técnicos recomendados.
7. Conclusiones y alineación con la gobernanza del SGSI.

5. RÚBRICA DE EVALUACIÓN

Criterio de evaluación	Muy bueno (100%)	Bueno (80%)	Logrado (60%)	No logrado (30%)	Deficiente (0%)
2.1.1 Conceptos y metodología	Aplica con total rigor los conceptos de activos, impacto, probabilidad, riesgo inherente y residual bajo marcos reconocidos (ISO 27005 / NIST).	Aplica correctamente los conceptos y la metodología de evaluación de riesgos, con imprecisiones menores que no afectan el resultado.	Aplica la fórmula de riesgo, pero presenta confusiones menores entre riesgo inherente y residual.	Confunde conceptos fundamentales de evaluación y gestión de riesgos.	No aborda los conceptos ni la metodología de evaluación de riesgos.
2.1.2 Operación de herramientas	Ejecuta herramientas de escaneo (nmap/auditoría) con destreza técnica respetando la arquitectura del laboratorio y documentando hallazgos.	Ejecuta correctamente las herramientas de escaneo, configura parámetros pertinentes y documenta la mayoría de los hallazgos.	Ejecuta las herramientas básicas de escaneo pero sin personalizar parámetros ni profundizar en el descubrimiento.	No logra operar las herramientas técnicas ni documentar resultados.	No presenta evidencia ni ejecuciones de herramientas de escaneo.
2.1.3 Interpretación y matriz	Prioriza los hallazgos mediante CVSS, construye una matriz de riesgo coherente y traduce datos técnicos a impacto de negocio.	Prioriza los hallazgos con CVSS y construye una matriz coherente, aunque presenta imprecisiones menores en el impacto de negocio.	Construye la matriz de riesgo pero la priorización no coincide adecuadamente con las métricas CVSS.	Presenta datos aislados sin estructurar la matriz ni interpretar resultados.	No desarrolla ni presenta la matriz de riesgo ni priorización.
2.1.4 Distinción y controles	Distingue claramente entre vulnerabilidades y amenazas, proponiendo controles preventivos, detectivos y correctivos aplicables.	Distingue correctamente vulnerabilidades y amenazas, y propone controles pertinentes con algunas oportunidades de mejora.	Distingue conceptos teóricos pero propone controles genéricos sin contemplar la arquitectura de seguridad.	Confunde vulnerabilidades con amenazas y no propone controles de mitigación viables.	No identifica vulnerabilidades ni propone controles de mitigación.

ANEXO 1. FORMATOS DE TABLAS PARA EL INFORME

Las siguientes tablas constituyen los formatos mínimos que debe completar el estudiante y están ordenadas según las fases del taller: inventario, evidencia técnica, clasificación de hallazgos, evaluación de riesgos y tratamiento. Pueden incorporar filas adicionales según la cantidad de activos, evidencias, hallazgos y riesgos identificados. Para la valoración C.I.A., el impacto y la probabilidad se utilizará una escala de 1 (Bajo) a 5 (Crítico); el riesgo se calculará como Impacto × Probabilidad. Los identificadores deben mantenerse vinculados entre tablas (A: activo; H: hallazgo; R: riesgo).

A. Inventario de activos y valoración C.I.A.

ID	Activo de información	Tipo / función	Propietario	Custodio	C	I	D	Criticidad	Justificación
A-01									
A-02									
A-03									

B. Registro de evidencia técnica de escaneo

N.º	Fecha y hora	Equipo origen	Objetivo	Herramienta / comando	Resultado relevante	Interpretación	Referencia de evidencia
1							
2							
3							

C. Clasificación de hallazgos y priorización CVSS

ID	Activo afectado	Hallazgo	Vulnerabilidad	Amenaza asociada	Vector CVSS	Puntaje	Severidad	¿Falso positivo?	Justificación
H-01									
H-02									
H-03									

D. Matriz de evaluación de riesgos

ID riesgo	Activo / hallazgo	Vulnerabilidad	Amenaza	Impacto inicial (1–5)	Probabilidad inicial (1–5)	Riesgo inherente	Nivel inherente	Control propuesto	Impacto residual (1–5)	Probabilidad residual (1–5)	Riesgo residual	Nivel residual
R-01												
R-02												
R-03												

E. Plan de tratamiento y controles

ID riesgo	Estrategia	Control específico	Tipo de control	Responsable	Plazo	Recursos	Indicador de cumplimiento	Evidencia esperada	Estado
R-01									
R-02									
R-03									